

Selecting a framework and mapping tables

From the overview to the decision



A grid to choose, a table to reuse: the three tutorial exercises walk through exactly this chain.

Session objectives

By the end of this tutorial:

- **Build** a grid of selection criteria for a framework, weighted and defensible before senior management
- **Explain** what a mapping table between frameworks is, what it contains and what it does not prove
- **Establish** a reasoned mapping between real requirements (NIS 2, ISO/IEC 27001, hygiene guide) while qualifying the relationship
- **Formulate** a framework recommendation for the MERIDIAN group, in ten lines that hold up before an Executive Committee

Prerequisites

- The overview from this morning's lecture: the four families of frameworks and the regulatory map of the MERIDIAN subsidiaries.
- The NIS 2 applicability characterization from the "CISO's briefing": essential, important or out of scope, subsidiary by subsidiary.

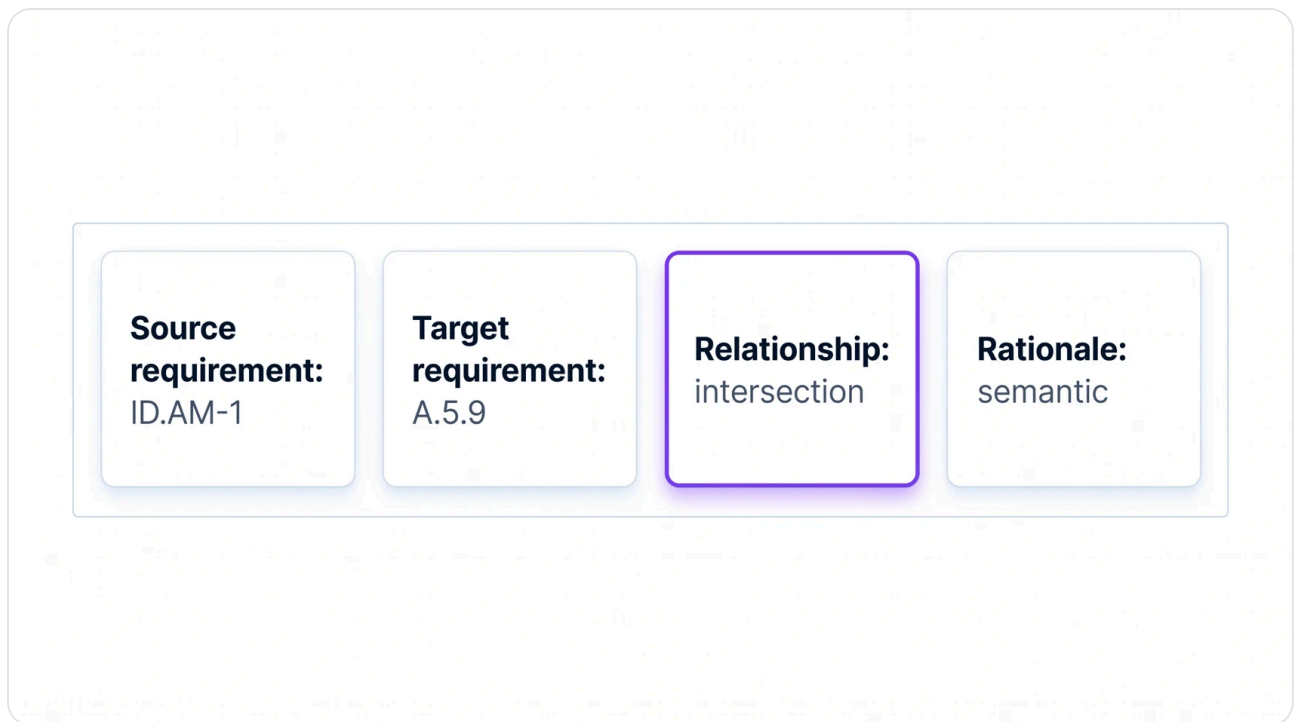
- The session 2 mapping: it will serve as an asset, in the literal sense, in exercise 2.

What to set down before getting hands-on

A quarter of an hour of framing, no more: two notions specific to this tutorial, which this morning's lecture deliberately left aside.

Selection criteria first. The problem is simple to state: this morning, three logics each argued for a different framework, the obligation for the ReCyF, client-facing proof for ISO/IEC 27001, the immediate first steps for the guides. An organization that chooses "by feel" actually chooses according to its executive's most recent conversation. A selection criterion is an attribute of the framework, observable and comparable, that is evaluated BEFORE deciding: is it mandatory for us, or will it become so; does it cover our actual scope, technical and organizational; does it allow defensible proof, certification or attestation; does it exist in French and is it maintained; can our tooling and our teams carry it; what does it cost, in licences as in effort. The mechanics: list the criteria, weight them according to the organization's context, score each candidate, and above all WRITE the justification for each score, because it is the justification that will be challenged, never the number. The limit, to know before the exercise: a weighted grid does not "compute" the right answer, it makes the deliberation transparent. If the grid's result offends common sense, it is the weighting that gets re-examined, not common sense.

The mapping table next, also known as a security mapping. The problem it addresses: frameworks overlap. The inventory of systems is required, in different wordings, by NIS 2, by Annex A of ISO/IEC 27001 and by the hygiene guide; an organization treating each text in isolation would do the inventory three times, with three diverging spreadsheets. A mapping table is a document that sets side by side, line by line, the requirements of a SOURCE framework and those of a TARGET framework, in order to reuse what is already done and spot what is missing. Here is the anatomy of a real line, taken from the NIST CSF to ISO 27001 mapping set delivered with the group's GRC tool, which contains 180 of them: source requirement ID.AM-1, asset management from the IDENTIFY function of the US framework presented in the lecture, target requirement A.5.9, relationship "intersect", justification "semantic". Four fields, and each one teaches something. The relationship first: in this whole mapping set, NOT ONE line declares two requirements equivalent, all say "intersection", a partial overlap. The justification next: "semantic" means the match is a judgement of meaning, not a legal equivalence. That is the fundamental limit of the object, and ANSSI itself states it at the top of its own framework comparison tool, made available « à titre purement informatif et indicatif » (purely for information and guidance). A mapping helps to understand and to reuse; it NEVER transfers compliance. Being compliant with the source does not make one compliant with the target, it gives a head start, which remains to be proven in the target's own terms.



Four fields per line, and the most important is the relationship: an intersection, never an equivalence.

Everything is now in place: a grid to choose, a table to reuse. The three exercises walk through exactly this chain.

Exercise 1: the MERIDIAN group's selection grid

The situation is Thursday's: the Executive Committee expects from the Group CISO a proposal for a single framework to serve as the backbone of security for the four subsidiaries. Three candidates are on the table, drawn from this morning's overview: ISO/IEC 27001:2022, the ReCyF, and ANSSI's Guide d'hygiène informatique.

The expected output: a complete selection grid, on the model below, with its weightings, its scores from 0 to 3 and a written one-line justification per score.

CRITERION	WEIGHTING (TO BE SET)	ISO/IEC 27001:2022	RECYF	HYGIENE GUIDE
Mandatory nature, current or upcoming	...	...	...	...
Coverage of the group's scope	...	...	...	...
Proof defensible before third parties	...	...	...	...
Maturity and stability of the text	...	...	...	...
Tooling and implementation workload	...	...	...	...

1. **Complete** the grid: set the weightings and justify them by the MERIDIAN context established since session 1 (hint: how much does the fact that Santé will very probably be an essential entity weigh? how much do Territoires' thirty or so client local authorities weigh?).

.....

2. **Identify** the criterion which, in the group's context, would deserve a right of veto rather than a weighting, and explain why a weighted average can mask a disqualifying criterion.

.....

3. **Analyse** the sensitivity of the result: which weighting would have to change, and by how much, for the ranking to flip between the top two candidates? What does this fragility, or this robustness, teach about the solidity of the recommendation?

.....

Suggested time: 15 minutes. Work in pencil: the grid will be taken up as is in the business case note at the end of the day.

Exercise 2: three requirements, three mappings

Here are three real requirements, copied from their official texts. The task: for each one, say what corresponds to it in the other two columns of the landscape, and qualify the relationship.

Requirement A, published by ANSSI in the NIS 2 requirement set of its comparison tool, reference 1.1-EI/EE: « L'entité liste l'ensemble de ses activités et services, y compris les activités et services qui ne correspondent pas aux critères pour lesquels l'entité constitue une entité importante ou essentielle » (the entity lists all of its activities and services, including the activities and services that do not match the criteria for which the entity constitutes an important or essential entity). For each entry in this list, the entity identifies an owner and lists the information systems supporting it.

Requirement B, security objective 2 of the ReCyF: the implementation of a digital security governance framework comprising an organization, roles and responsibilities, compliance management processes, and an information systems security policy.

Requirement C, measure 4 of the hygiene guide, known since session 2: identify the most sensitive information and servers and maintain a network diagram.

Instructions, for each requirement:

1. **Designate** the corresponding element on the ISO/IEC 27001:2022 side: the block (clauses 4 to 10, or Annex A) and, if it is Annex A, the most relevant theme among the four seen this morning (hint: ask whether the requirement is about organizing the steering or deploying a control).

.....

2. **Qualify** the relationship with one of the three verdicts: equivalence, intersection, no correspondence; then justify in one sentence what the source requires that the target does not, or the reverse.

.....

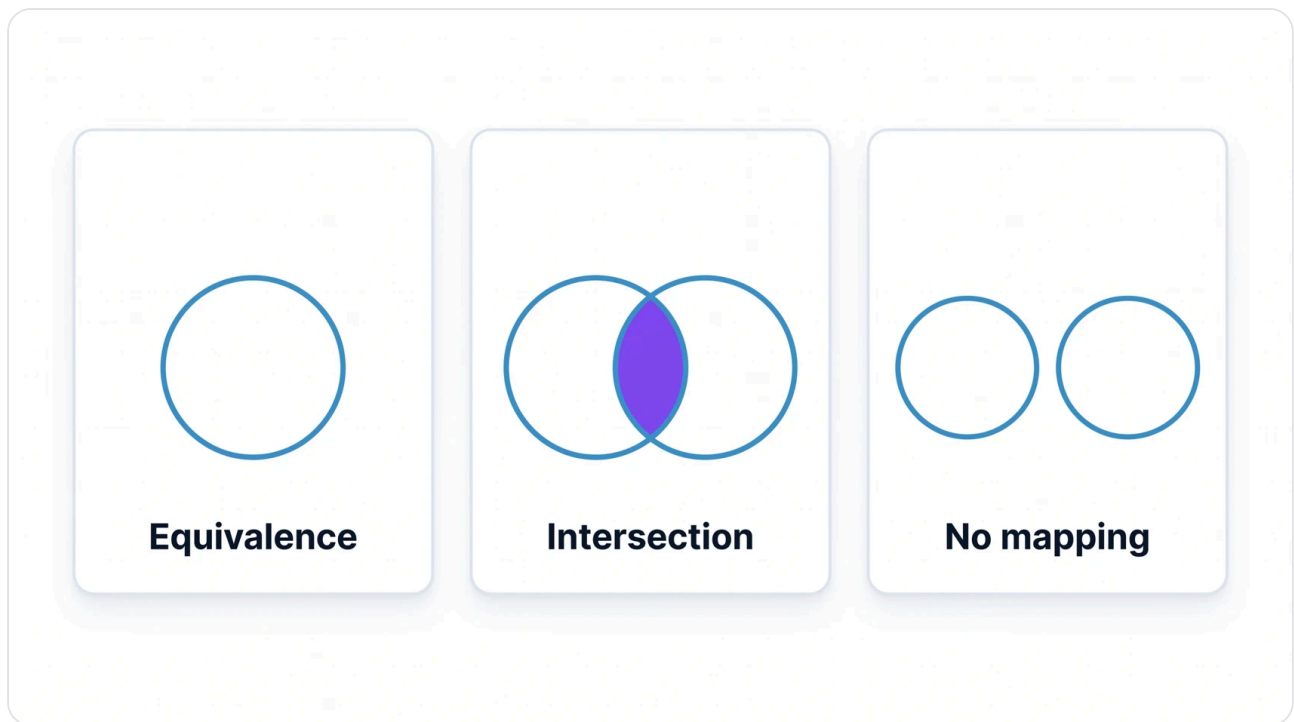
3. **Spot** what the MERIDIAN group ALREADY has that satisfies all or part of the source requirement, citing precisely the deliverable from sessions 1 or 2 concerned.

.....

4. **Conclude** in two sentences: what does this exercise say about the idea "we will be NIS 2 compliant since we apply ISO 27001"? Lean on one of the three cases to show it.

.....

Suggested time: 20 minutes. The trap of the exercise is known in advance: the temptation to tick "equivalence" wherever the subjects look alike. Reread the anatomy from the framing: the relationship is judged on what the texts REQUIRE, not on what they talk about.



The relationship is judged on what the texts require, and the real-world case is almost always the intersection.

Exercise 3: the ten-line recommendation

Last move, the one that directly prepares the end-of-day lab: turning the grid and the mappings into a recommendation.

Draft a paragraph of at most ten lines, addressed to the Executive Committee, which: names the recommended backbone framework for the group; gives the two decisive arguments drawn from the grid; states explicitly what this choice does NOT cover and how the rest will be handled; and ends with the decision requested from the committee. Realism constraint: the paragraph must remain true whether the Résilience law is promulgated in three months or in eighteen.

Suggested time: 10 minutes. It is an assumed rough draft: the complete, reasoned version will be the business case note of the final lab.

Answer keys and assessment criteria

Answer key for exercise 1: the grid and its traps

There is no single right weighting, there are defensible weightings; here is the essence of what the grid was meant to bring out. The mandatory nature weighs heavily for MERIDIAN: at least two subsidiaries will fall within NIS 2, which gives the ReCyF a structural long-term advantage, even though it remains today a non-binding working version, something the "maturity and stability" column was meant to make it pay for. ISO/IEC 27001 dominates the "defensible proof" column: it is the only one of the three candidates that leads to third-party certification, decisive for Territoires, whose client local authorities demand guarantees, and useful to Santé with respect to its partners. The hygiene guide wins the "implementation workload" column and loses the others: it is a starting point, not a group backbone.

Question 2, the expected veto criterion: coverage of the scope, or the mandatory nature, depending on the line of argument taken. The idea that earns the points: a weighted average compensates, yet some criteria cannot be compensated. A framework that ignored Santé's sector-specific obligations would remain disqualifying even with a 3 everywhere else; that is the difference between a score and a condition.

Question 3, sensitivity: if a modest variation in a single weighting flips the ranking, the recommendation rests on fine-tuning that senior management has not validated, and the business case note must say so honestly, for example by presenting both scenarios. If the ranking holds, say that too: it is an argument. The "sensitivity test" reflex is what separates an analysis from a staging.

Answer key for exercise 2: the three expected verdicts

Requirement A (list activities, services, owners and information systems): on the ISO/IEC 27001 side, it touches both blocks, and that was the subtlety: the context of the organization belongs to the management clauses, the operational inventory of assets belongs to the organizational theme of Annex A. Expected verdict: intersection, and certainly not equivalence, because the NIS 2 requirement demands listing ALSO the activities outside the applicability criteria, which no ISO requirement words that way. What MERIDIAN already has: the session 2 mapping, business assets and supporting assets per subsidiary, which answers to the letter the "lists the information systems supporting it"; what is missing is the named owner per activity, which the session 1 RACI matrix makes it possible to complete in one meeting.

Requirement B (governance framework): the ISO correspondence is the most straightforward of the three, on the management clauses side, with an overflow into the organizational theme of Annex A for the policies. Verdict: strong intersection, and it is the case that gives full meaning to the acceptable means of compliance seen this morning: the ReCyF itself accepts an ISMS certified to ISO/IEC 27001:2022 as a demonstration of THIS objective, over the certified scope. What MERIDIAN already has: the governance scoping note and the RACI from session 1, that is, the embryo of the "organization" and "roles and responsibilities" points; the framework PSSI exists as a set of codified directives, compliance management remains to be built, and that is precisely what the GRC tool will carry.

Requirement C (measure 4 of the hygiene guide): on the ISO side, intersection with the organizational theme of Annex A (the inventory and the topology belong to the controls, not to management); on the NIS 2 side, an obvious intersection with requirement A, and this was worth saying: mappings compose, C overlaps A which overlaps ISO, but each overlap is partial and the losses add up. The "simplified" network diagram of the hygiene guide is less demanding than the full inventory of requirement A: an organization compliant with C has not finished A.



Each overlap is partial: the losses add up

Mappings compose, but each overlap is partial and the losses add up from one text to the next.

Question 4, the expected conclusion: the claim "NIS 2 compliant since ISO 27001" is false in the strict sense, and the three cases each show it in their own way: A requires more broadly than the ISO inventory, B is covered only over the certified scope and for that single objective, C shows that even two closely related texts lose something at each crossing. The exact wording of the official doctrine, seen this morning, fits on one line: no general presumption of conformity, but an acceptable means, bounded to one objective and one scope. If the conclusion handed in said that in other words, it is correct.

Answer key for exercise 3: what was expected of the paragraph

Form first: ten lines, a decision requested in the final sentence, no date commitment that the law could contradict. Substance next, as an example of a defensible recommendation: ISO/IEC 27001:2022 as the group's backbone, because it is the only candidate that both structures a single governance for four subsidiaries with disparate obligations AND produces proof enforceable towards Territoires' clients; complemented, not rivalled, by active monitoring of the ReCyF, whose objectives will become ANSSI's control framework, the mapping table serving to reuse every ISO effort in the future NIS 2 compliance. The reverse recommendation, ReCyF first, is also defensible, provided its fragility is owned: a working document, liable to evolve until the decrees. What is not defensible: recommending the hygiene guide alone as the backbone of a MERIDIAN group of 7 700 employees, or promising "automatic" regulatory compliance through certification.

Assessment criteria

CRITERION	EXPECTED	POINTS OF ATTENTION
Grid (ex. 1)	Weightings justified by the MERIDIAN context, every score accompanied by a one-line justification	A grid without justifications is an opinion laid out in a table
Veto and sensitivity (ex. 1)	One disqualifying criterion identified, one flip test carried out	Confusing "low score" with "condition not met"
Mappings (ex. 2)	Three qualified verdicts, no unjustified "equivalence", reuse of the S1/S2 deliverables cited precisely	Ticking by resemblance of subject instead of comparing the requirements
Conclusion (ex. 2)	The doctrine "no presumption, one bounded means" rephrased with a case in support	Reciting the doctrine without linking it to one of the three cases
Recommendation (ex. 3)	Ten lines, two grid arguments, the gaps owned, a decision requested	A recommendation that promises a compliance no text grants